SECURITY DEVELOPMENT LIFECYCLE AND ACTIVITIES

Jingyue Li

13 March 2026

AGENDA

Security Development Lifecycle Models

Industry Best Practices

WE HOLD THESE TRUTHS TO BE SELF-EVIDENT

Software security is more than a set of security functions

- Not magic crypto fairy dust
- Not silver-bullet security mechanisms

Non-functional aspects of design are essential

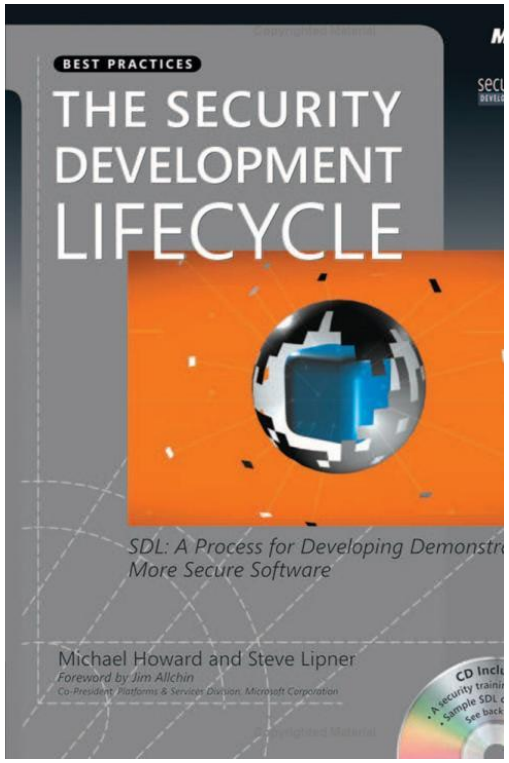
Security is an emergent property of the entire system (just like quality)

- Not only do security products need software security!

2006: A SHIFT FROM PHILOSOPHY TO HOW TO

Integrating best practices into large organizations' SDLC (software development lifecycle)

- Touchpoints
- Microsoft's SDL (Security Development Lifecycle)
- OWASP Comprehensive, Lightweight Application Security Process (CLASP)
- Software Assurance Maturity Model (OpenSAMM)
- Building Security In Maturity Model (BSIMM)



PRESCRIPTIVE VS. DESCRIPTIVE MODELS

Prescriptive Models

- Prescriptive models describe what you should do
  - Touchpoints
  - Microsoft SDL
  - OWASP CLASP
  - Software Assurance Maturity Model (OpenSAMM)
- Every firm has a methodology it follows (often a hybrid)

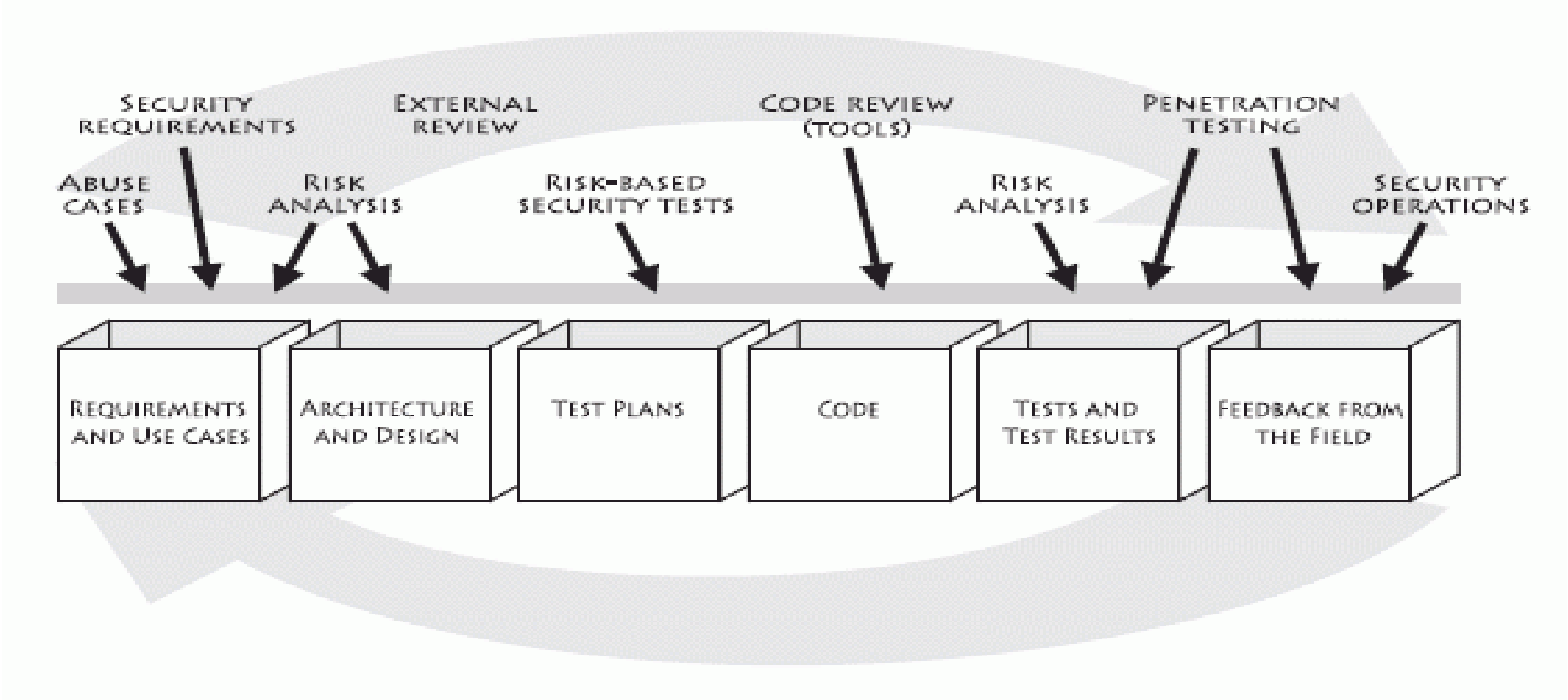
Descriptive Models

- Descriptive models describe what is actually happening
- The BSIMM is a descriptive model that can be used to measure any number of prescriptive SSDLs (Secure Software Development Lifecycle)
- For accessment and benchmarking

PRESCRIPTIVE MODELS

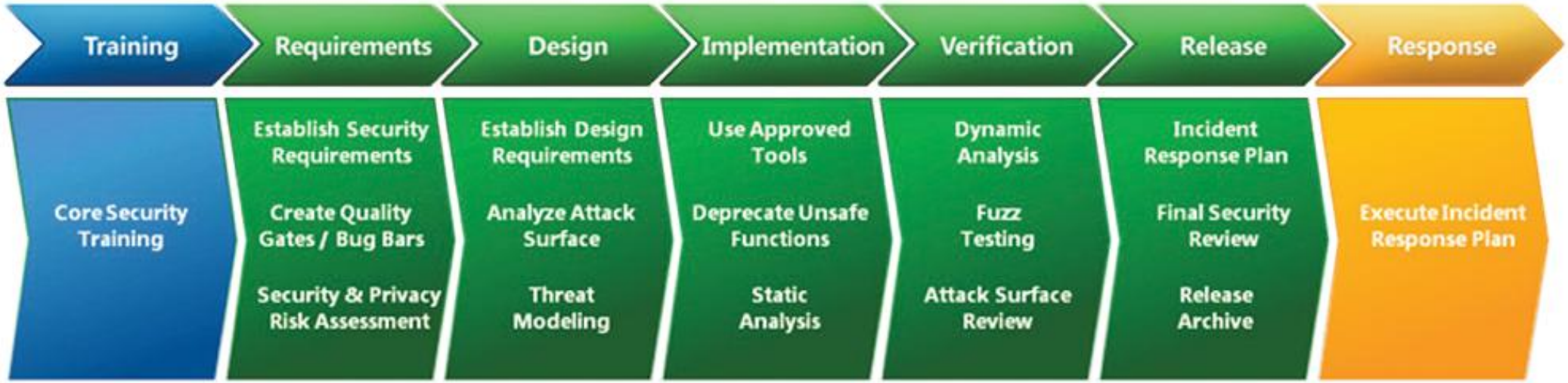
SEVEN TOUCHPOINTS FOR SOFTWARE SECURITY

Security touchpoints are specific, actionable security activities integrated throughout the Software Development Life Cycle (SDLC) to proactively identify vulnerabilities and build secure systems



MICROSOFT SDL

The Microsoft Security Development Lifecycle (SDL) is Microsoft's security assurance process for software development that builds security into every phase of software development and provides defense-in depth guidance and protection.



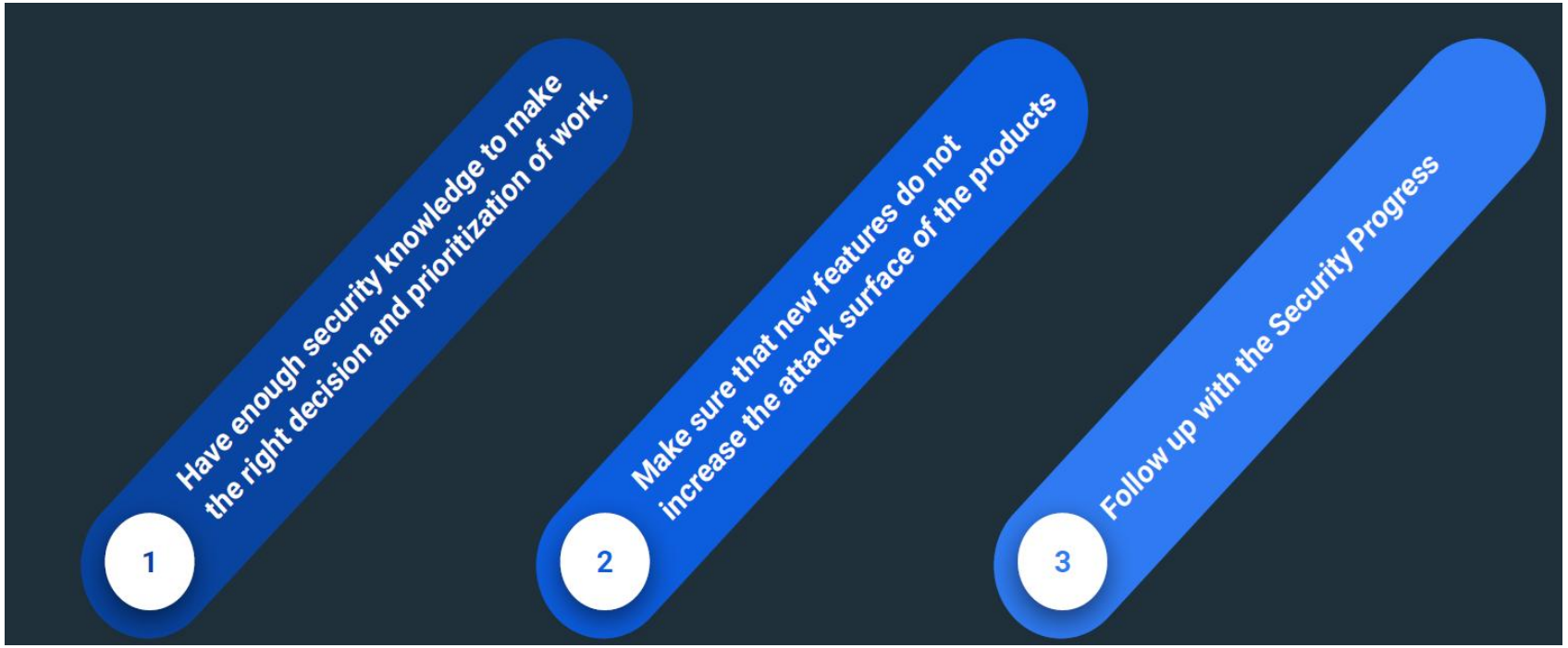
https://www.microsoft.com/en-us/securityengineering/sdl

OWASP CLASP (COMPREHENSIVE, LIGHTWEIGHT APPLICATION SECURITY PROCESS)

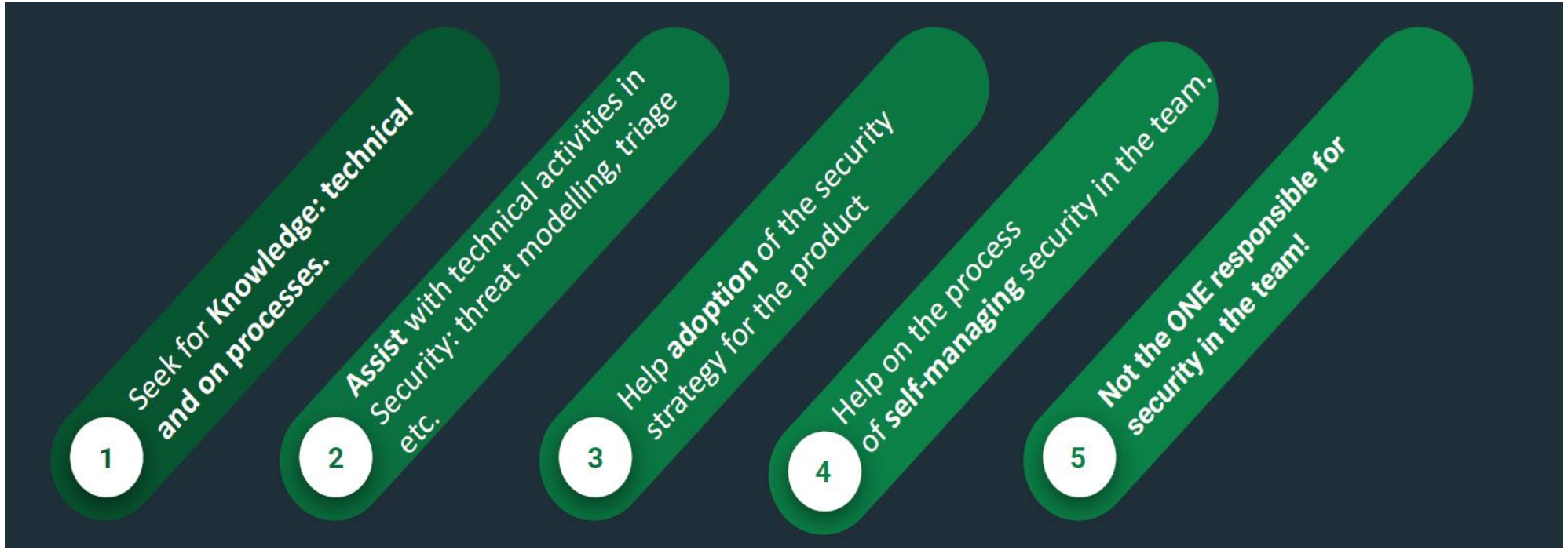
A structured, role-based framework designed to integrate security into existing Software Development Lifecycles (SDLC)

- **Role-Based Activities:** Assigns specific security activities to roles like **project managers**, **security auditors**, **and developers**.
- **Could be customized** based on the contexts of the companies.
- **Application Areas:** Covers requirements, design, implementation, and testing.

Note: Although the CLASP process is no longer in use, we refer to it as an example to illustrate the role-based approach.



THE ROLE OF THE MANAGERS



THE ROLE OF SECURITY ENGINEER / CHAMPION

THE ROLE OF THE DEVELOPERS

Software Assurance Maturity Model

OpenSAMM

ISO/IEC 27001:2022

https://www.opensamm.org/

https://www.iso.org/standard/27001

OpenSAMM maturity levels

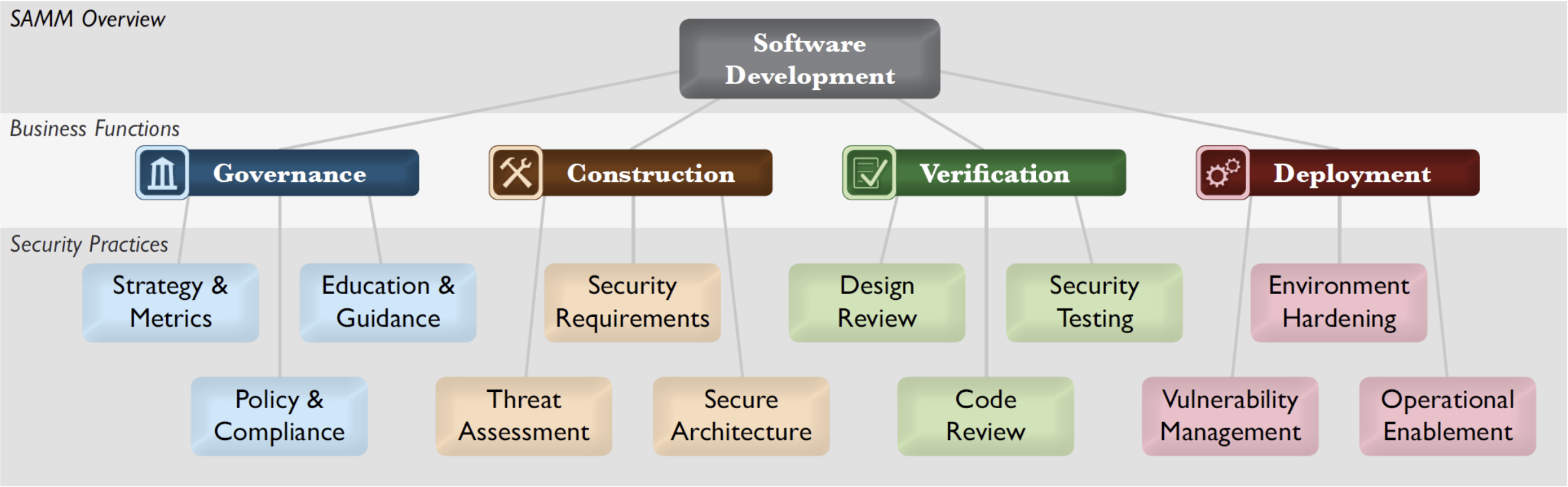
0 - Implicit starting point representing the activities in the Practice being unfulfilled

1- Initial understanding and ad hoc provision of Security Practice

2 - Increase efficiency and/or effectiveness of the Security Practice

3 - Comprehensive mastery of the Security Practice at scale

OpenSAMM


SAMM Overview
Software Development
Business Functions
Governance
Construction
Verification
Deployment
Security Practices
Strategy & Metrics
Education & Guidance
Security Requirements
Design Review
Security Testing
Environment Hardening
Policy & Compliance
Threat Assessment
Secure Architecture
Code Review
Vulnerability Management
Operational Enablement

SAMM ASSESSMENT

Analyze your security posture using our maturity measurement tool.

Attribution and License | **Interview** | Scorecard | Roadmap | Roadmap Chart | Lookups | imp-questions | imp-answers

Design

		Threat Assessment		Answer		
Application Risk Profile	1	**Do you classify applications according to business risk based on a simple and predefined set of questions?** An agreed-upon risk classification exists The application team understands the risk classification The risk classification covers critical aspects of business risks the organization is facing The organization has an inventory for the applications in scope	0		0	0,000
	2	**Do you use centralized and quantified application risk profiles to evaluate business risk?** The application risk profile is in line with the organizational risk standard The application risk profile covers impact to security and privacy You validate the quality of the risk profile manually and/or automatically The application risk profiles are stored in a central inventory	0		0	0,000
	3	**Do you regularly review and update the risk profiles for your applications?** The organizational risk standard considers historical feedback to improve the evaluation method Significant changes in the application or business context trigger a review of the relevant risk profiles	0		0	0,000
Threat Modeling	1	**Do you identify and manage architectural design flaws with threat modeling?** You perform threat modeling for high-risk applications You use simple threat checklists, such as STRIDE You persist the outcome of a threat model for later use	0		0	
	2	**Do you use a standard methodology, aligned on your application risk levels?** You train your architects, security champions, and other stakeholders on how to do practical threat modeling Your threat modeling methodology includes at least diagramming, threat identification, design flaw mitigations, and how to validate your threat model artifacts Changes in the application or business context trigger a review of the relevant threat models You capture the threat modeling artifacts with tools that are used by your application teams	0		0	
	3	**Do you regularly review and update the threat modeling methodology for your applications?** The threat model methodology considers historical feedback for improvement You regularly (e.g., yearly) review the existing threat models to verify that no new threats are relevant for your applications You automate parts of your threat modeling process with threat modeling tools	0		0	
		Security Requirements		**Answer**		
Software Requirements	1	**Do project teams specify security requirements during development?** Teams derive security requirements from functional requirements and customer or organization concerns Security requirements are specific, measurable, and reasonable Security requirements are in line with the organizational baseline	0		0	0,000
	2	**Do you define, structure, and include prioritization in the artifacts of the security requirements gathering process?** Security requirements take into consideration domain specific knowledge when applying policies and guidance to product development Domain experts are involved in the requirements definition process You have an agreed upon structured notation for security requirements Development teams have a security champion dedicated to reviewing security requirements and outcomes	0		0	0,000
	3	**Do you use a standard requirements framework to streamline the elicitation of security requirements?** A security requirements framework is available for project teams The framework is categorized by common requirements and standards-based requirements The framework gives clear guidance on the quality of requirements and how to describe them The framework is adaptable to specific business requirements	0		0	0,000
Supplier	1	**Do stakeholders review vendor collaborations for security requirements and methodology?** You consider including specific security requirements, activities, and processes when creating third-party agreements A vendor questionnaire is available and used to assess the strengths and weaknesses of your suppliers	0		0	
	2	**Do vendors meet the security responsibilities and quality measures of service level agreements defined by the organization?** You discuss security requirements with the vendor when creating vendor agreements Vendor agreements provide specific guidance on security defect remediation within an agreed upon timeframe The organization has a templated agreement of responsibilities and service levels for key vendor security processes You measure key performance indicators	0		0	

Dicti

DESCRIPTIVE MODELS

Self-assessment and benchmarking

The Building Security In Maturity Model (BSIMM)

BSIMM

MONKEYS EAT BANANAS

Illustartion by Amber de Bruin https://www.flickr.com/photos/amberdebruin CC-BY

- BSIMM is not about good or bad ways to eat bananas or banana best practices
- BSIMM is about observations
- BSIMM is descriptive, not prescriptive
- BSIMM describes and measures multiple approaches

EXAMPLE ACTIVITY (ARCHITECTURAL ANALYSIS)

[AA1.2] **Perform design review for high-risk applications.**
The organization learns about the benefits of architecture analysis by seeing real results for a few high-risk, high-profile applications. The reviewers must have some experience performing architecture analysis and breaking the architecture being considered. If the SSG is not yet equipped to perform an in-depth architecture analysis, it uses consultants to do this work. Ad hoc review paradigms that rely heavily on expertise may be used here, though in the long run they do not scale.

EXAMPLE 2 (CONFIG. MGT & VULNERABILITY MGT.)

[CMVM3.4] **Operate a bug bounty program.** The organization solicits vulnerability reports from external researchers and pays a bounty for each verified and accepted vulnerability received. Payouts typically follow a sliding scale linked to multiple factors, such as vulnerability type (e.g., remote code execution is worth $10,000 versus CSRF is worth $750), exploitability (demonstrable exploits command much higher payouts), or specific services and software versions (widely-deployed or critical services warrant higher payouts). Ad hoc or short-duration activities, such as capture-the-flag contests, do not count. [This is a new activity that will be reported on in BSIMM6.]

BSIMM-V MEASUREMENTS: REAL-WORLD DATA

- **Initiative age**
  - Average: 6 years
  - Newest: 0.4
  - Oldest: 18.1
  - Median: 5.3
- **Satellite size**
  - Average: 29.6
  - Smallest: 0
  - Largest: 400
  - Median: 4
- **SSG size**
  - Average: 14.78
  - Smallest: 1
  - Largest: 100
  - Median: 7
- **Dev size**
  - Average: 4190
  - Smallest: 11
  - Largest: 30,000
  - Median: 1600

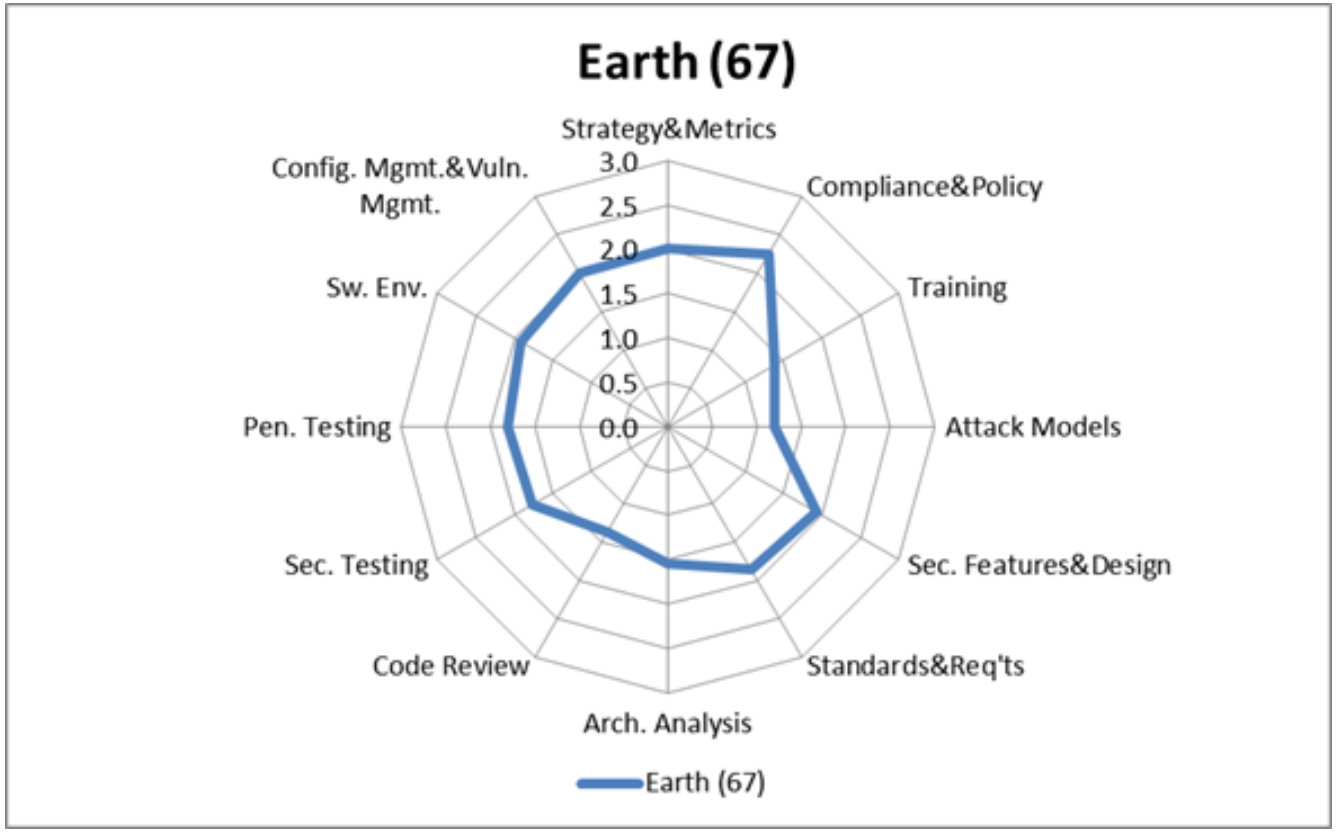
Average SSG size: 1.4% of dev group size

BSIMM-V SCORECARD (67 FIRMS)

(n=67)

1. Use external penetration testers to find problems. (62)
2. Ensure host and network security basics are in place. (61)
3. Identify software defects found in operations monitoring and feed them back to development. (59)
4. Identify gate locations, gather necessary artifacts. (57)
5. Perform security feature review. (56)
6. Drive tests with security requirements and security features. (55)
7. Build and publish security features. (54)
8. Identify PII obligations. (52)
9. Provide awareness training. (50)
10. Use automated tools along with manual review. (50)
11. Create a data classification scheme and inventory. (43)
12. Create security standards. (48)

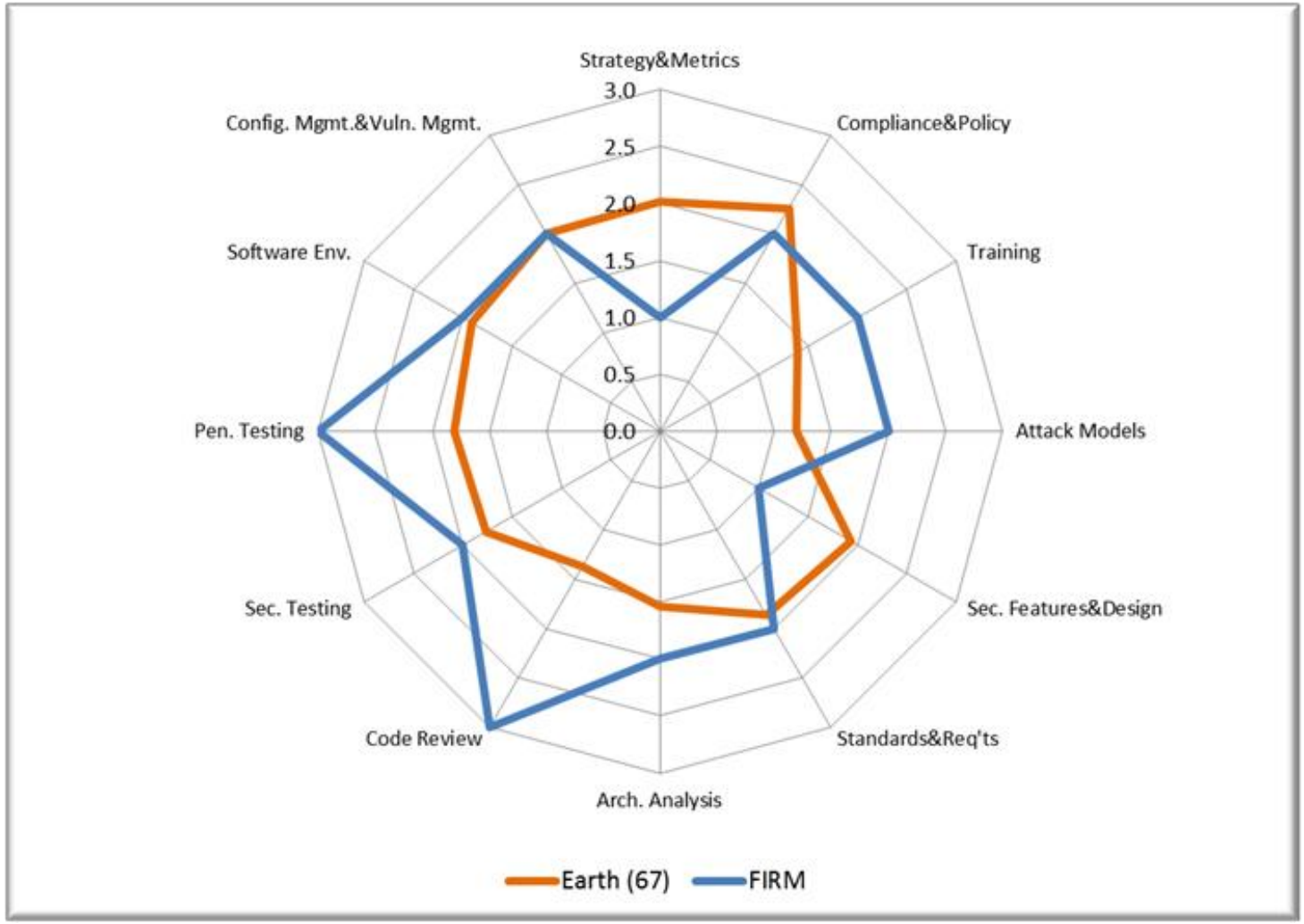
Governance		Intelligence		SSDL Touchpoints		Deployment	
Activity	Observed	Activity	Observed	Activity	Observed	Activity	Observed
[SM1.1]	44	[AM1.1]	21	[AA1.1]	56	[PT1.1]	62
[SM1.2]	34	[AM1.2]	43	[AA1.2]	35	[PT1.2]	[illegible]
[SM1.3]	[illegible]	[AM1.3]	30	[AA1.3]	24	[PT1.3]	43
[SM1.4]	57	[AM1.4]	12	[AA1.4]	42	[PT2.2]	24
[SM1.6]	[illegible]	[AM1.5]	42	[AA2.1]	10	[PT2.3]	27
[SM2.1]	26	[AM1.6]	16	[AA2.2]	8	[PT3.1]	13
[SM2.2]	31	[AM2.1]	7	[AA2.3]	20	[PT3.2]	8
[SM2.3]	27	[AM2.2]	11	[AA3.1]	11		
[SM2.5]	20	[AM3.1]	4	[AA3.2]	4		
[SM3.1]	16	[AM3.2]	6				
[SM3.2]	6						
[CP1.1]	43	[SFD1.1]	54	[CR1.1]	24	[SE1.1]	[illegible]
[CP1.2]	52	[SFD1.2]	53	[CR1.2]	34	[SE1.2]	61
[CP1.3]	45	[SFD2.1]	26	[CR1.4]	50	[SE2.2]	[illegible]
[CP2.1]	24	[SFD2.2]	29	[CR1.5]	23	[SE2.4]	25
[CP2.2]	28	[SFD2.3]	9	[CR1.6]	25	[SE3.2]	10
[CP2.3]	29	[SFD3.1]	13	[CR2.2]	10	[SE3.3]	9
[CP2.4]	25	[SFD3.2]	9	[CR2.5]	15		
[CP2.5]	35			[CR3.1]	18		
[CP3.1]	14			[CR3.2]	4		
[CP3.2]	11			[CR3.3]	6		
[CP3.3]	8			[CR3.4]	1		
[T1.1]	50	[SR1.1]	48	[ST1.1]	51	CMVM1.1	[illegible]
[T1.5]	29	[SR1.2]	43	[ST1.3]	55	CMVM1.2	59
[T1.6]	23	[SR1.3]	45	[ST2.1]	27	CMVM2.1	[illegible]
[T1.7]	33	[SR1.4]	27	[ST2.3]	13	CMVM2.2	44
[T2.5]	9	[SR2.1]	23	[ST2.4]	11	CMVM2.3	30
[T2.6]	13	[SR2.2]	19	[ST3.1]	8	CMVM3.1	6
[T2.7]	9	[SR2.3]	19	[ST3.2]	6	CMVM3.2	6
[T3.1]	4	[SR2.4]	22	[ST3.3]	5	CMVM3.3	2
[T3.2]	4	[SR2.5]	8	[ST3.4]	7		
[T3.3]	8	[SR3.1]	12				
[T3.4]	9						
[T3.5]	5						



EARTH (67) (BSIMM-V)

BSIMM-V AS A MEASURING STICK

- Compare a firm with peers using the high-water mark view
- Compare business units



109 firms in BSIMM8 community

© 2017 Synopsys, Inc.

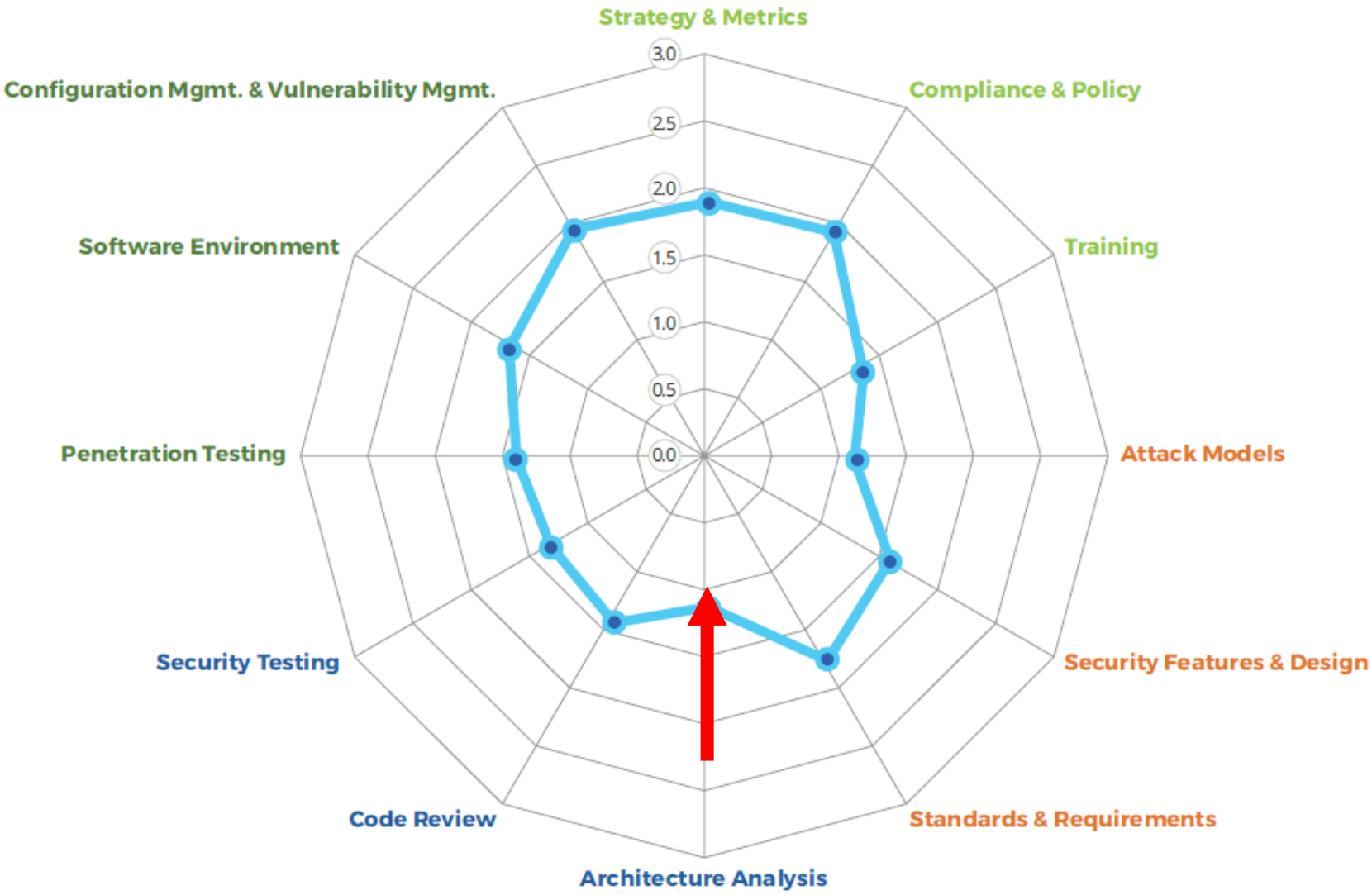
BSIMM9 MEASUREMENTS: REAL-WORLD DATA (120 FIRMS)

- **Initiative age**
  - Average: 4.13 years
  - Newest: 0.1
  - Oldest: 19
  - Median: 2.5
- **Satellite size**
  - Average: 52.4
  - Smallest: 0
  - Largest: 2 250
  - Median: 0
- **SSG size**
  - Average: 13.3
  - Smallest: 1
  - Largest: 160
  - Median: 5,5
- **Dev size**
  - Average: 3 463
  - Smallest: 20
  - Largest: 45,000
  - Median: 900

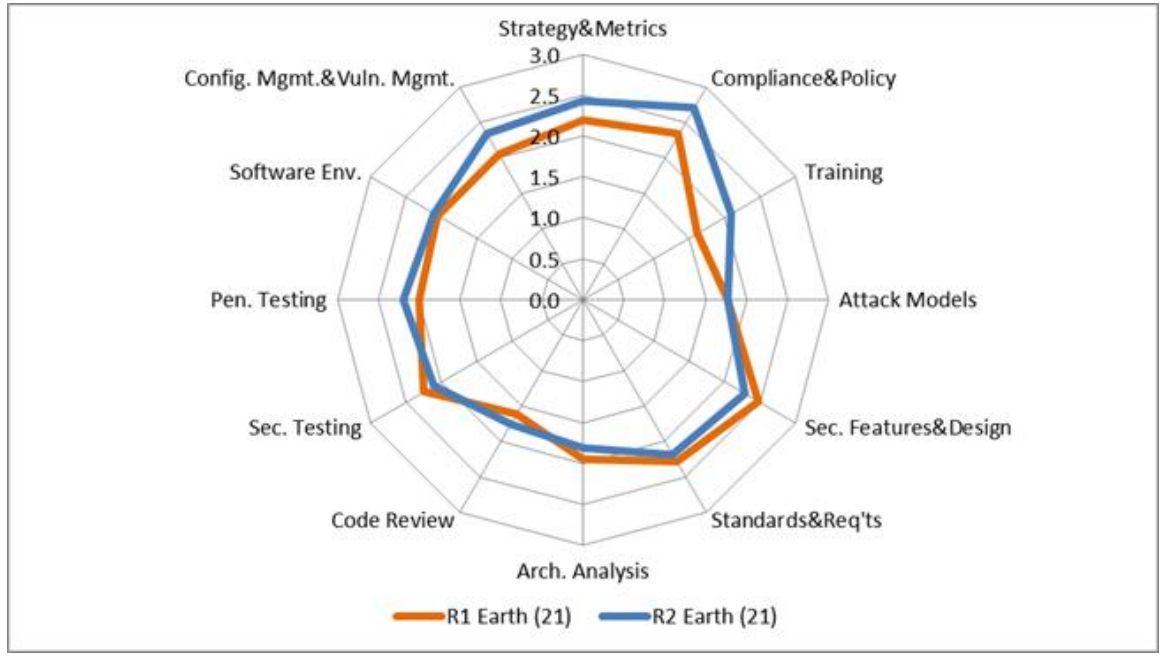
Average SSG size: 1.33% of dev group size

BSIMM

EARTH (120) (BSIMM9)



BSIMM-V LONGITUDINAL: IMPROVEMENT OVER TIME



- 21 firms measured twice (an average of 24 months apart)
- Show how firms improve
  - An average of 16% activity increase

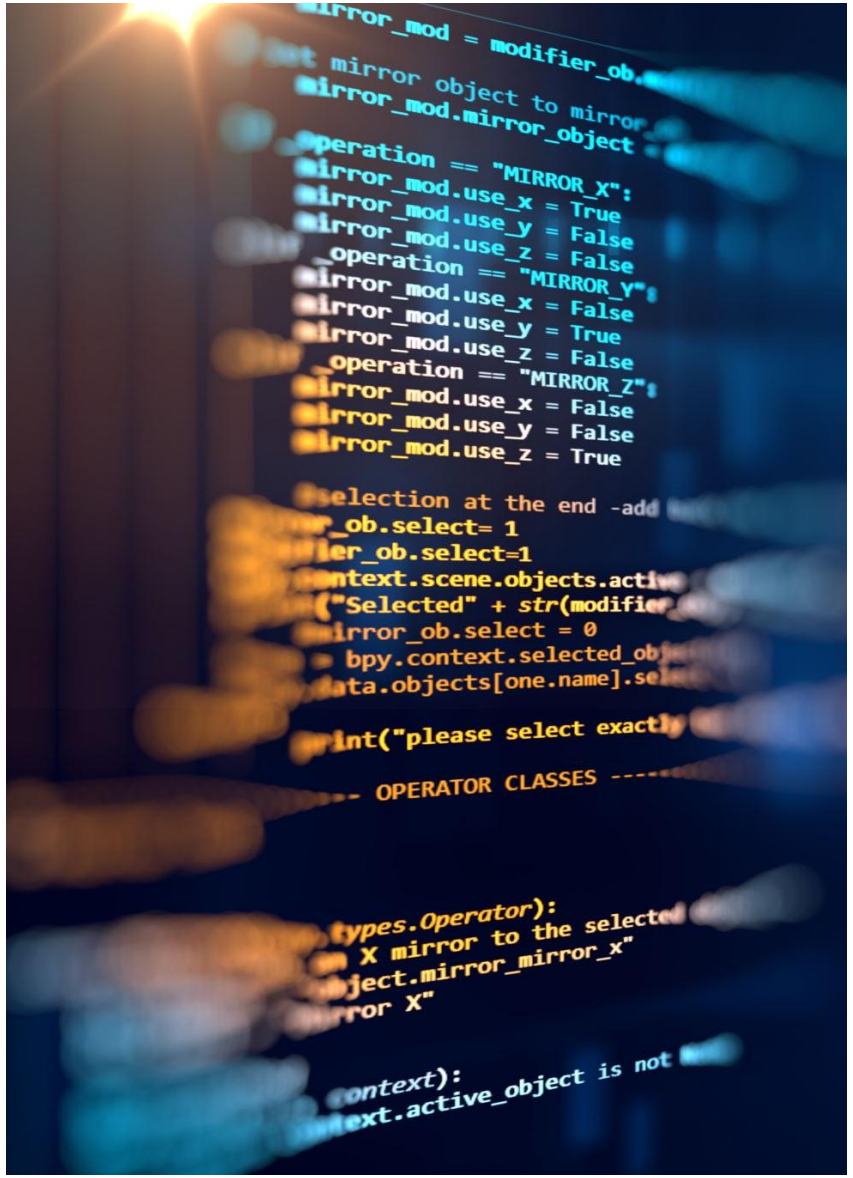
SECURITY DEVELOPMENT LIFECYCLE VS. SECURITY STANDARDS

SECURITY STANDARDS

Definition: Established, documented, and often mandatory frameworks that provide a "seal of approval" or baseline for security.

Examples:

- **NIST SSDF (800-218):** Best practices for developing secure software.
- **OWASP ASVS:** Detailed security requirements for web applications.
- **ISO 27001:** Information security management standard (includes secure development).
- **PCI DSS:** Standards for handling payment information



SDLC VS. SECURITY STANDARD

Differences:

SDLC: **Methodology & Process:** "How to build it“

Standard: **Requirements & Compliance:** "What to build"

How They Work Together:

SDLC = Action: "We are testing for vulnerabilities during every build."

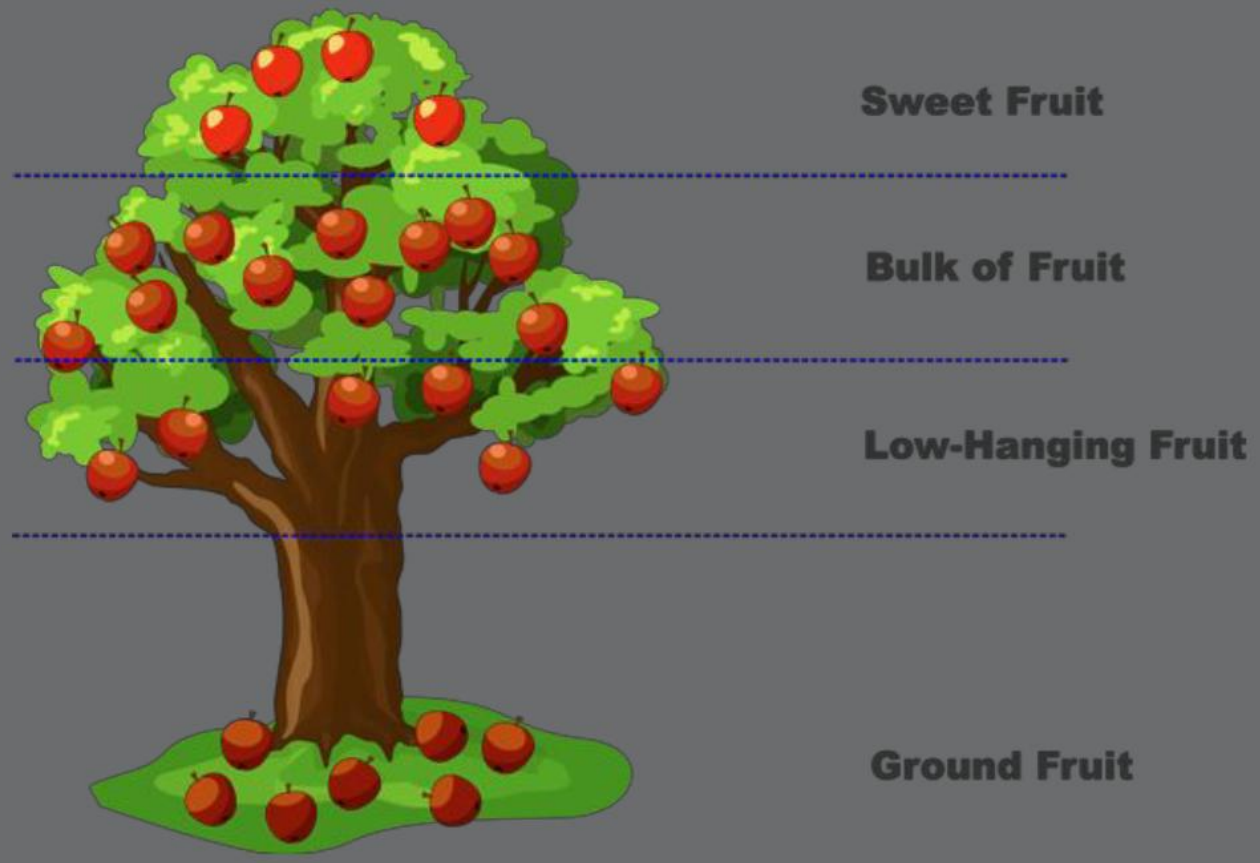
Standards = Benchmark: "We are testing for vulnerabilities to comply with ISO 27001.

AGENDA

Security Development Lifecycle Models

Industry Best Practices

What will you do to pick all fruits?



RETHINK ROLES AND RESPONSIBILITIES TOWARDS SECURITY

Role/ Position	Responsibility
Chief Information Officer	Development and implementation of Security policy Add Text Here
Information Management Manager	Asset classification and control Add Text Here
IT Manger	Development of organizational security framework Add Text Here
Risk Management Officer	Development and implementation of risk management program Add Text Here

RETHINK TRAINING PROGRAM

INSTRUCTOR LED TRAINING

E-LEARNING

SIMULATION EMPLOYEE TRAINING

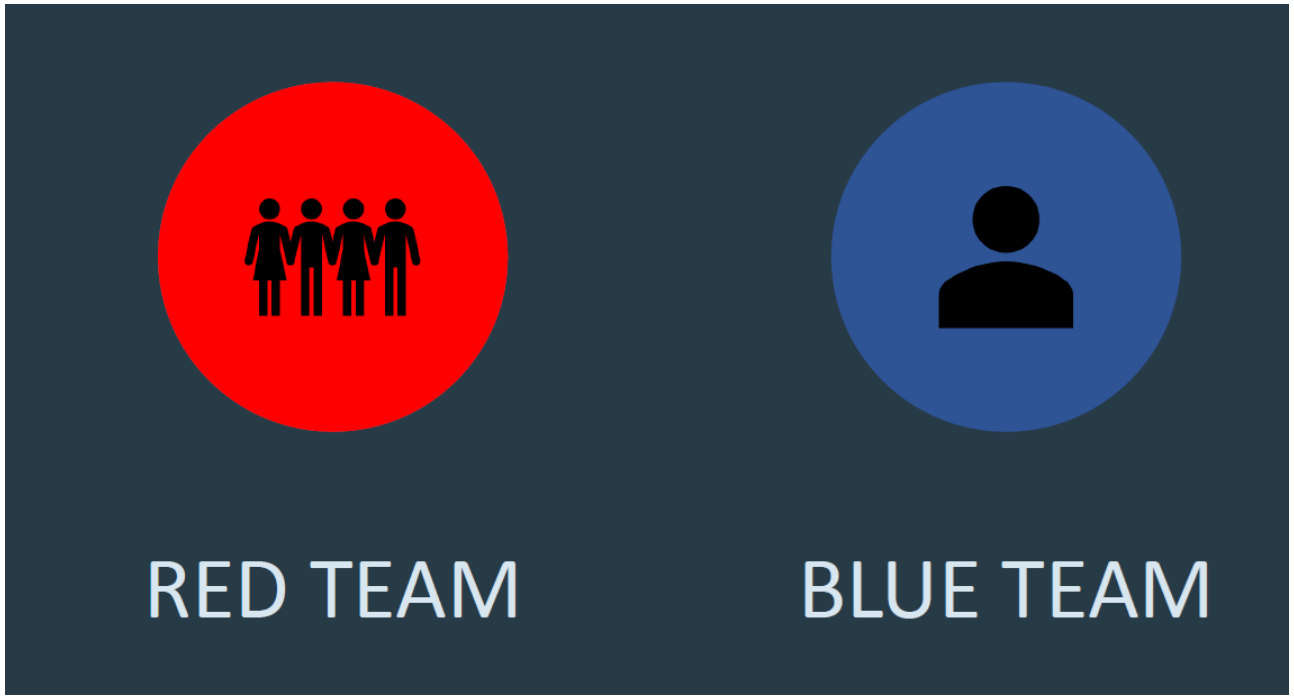
HANDS-ON TRAINING

COACHING OR MENTORING

GROUP DISCUSSSIONS

ROLE PLAYING

BUG BOUNTY



RESPONSIBLE DISCLOSURE

Current Disclosure Practices

- Full – Tell the world before the vendor
- Responsible – Tell the vendor before the world
- Profit driven – Tell a paying third party; hope they tell the vendor and the world
- Non – Tell no-one

RESPONSIBLE DISCLOSURE CHALLENGES

A less than perfect world?

- The vendor will probably not appreciate your efforts
- The vendor may become unresponsive
- The vendor may appear to be technically obtuse
- The vendor may not have experience in dealing with vulnerabilities
- The vendor may wish to communicate insecurely (unencrypted email etc.)
- You might be sued…

SUMMARY

- Security measures must be embedded across all phases of the software development lifecycle
- Prescriptive vs. Descriptive models
- Some industry best practices
  - Considering cost-effectiveness
  - Everybody shall be responsible for security
  - Training is critical
  - Bug Bounty